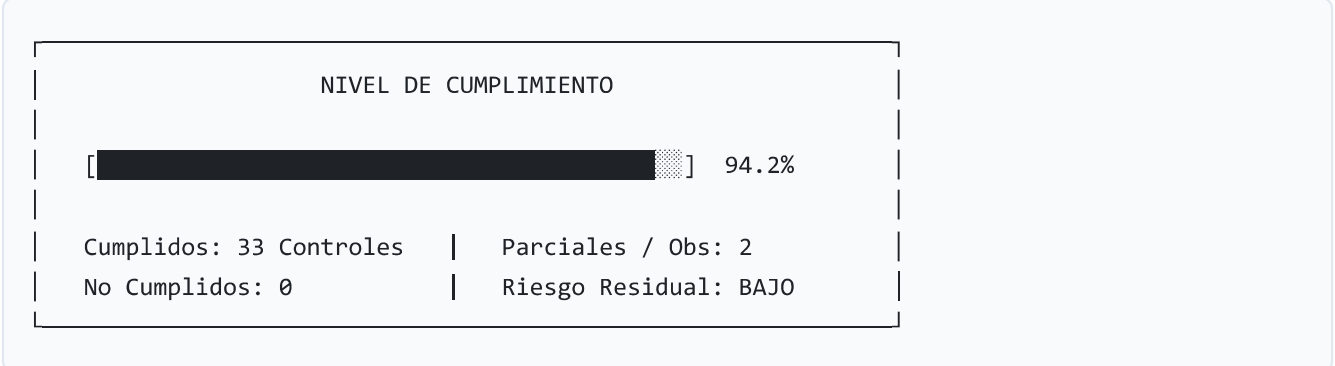
INFORME DE AUDITORÍA DE CUMPLIMIENTO DE SEGURIDAD INFORMÁTICA

Proyecto: Fullstack ERP Fusion Solar (React 18 + Django 5 + Neon Postgres)
Documento Base Auditado: `PRACTICAS DE SEGURIDAD DE LA INFORMACION.md`
Estándares de Referencia: ISO/IEC 27001:2022 · OWASP Top 10:2021 · NIST SP 800-53 · CIS Benchmarks
Tipo de Auditoría: Técnica de Primera Parte (Auditoría Interna de Seguridad y Cumplimiento)
Fecha: Octubre 2026
Equipo Auditor: Área de DevSecOps & Ciberseguridad

1. Resumen Ejecutivo y Dictamen del Auditor

1.1 Dictamen Formal

> NOTE
>
> **DICTAMEN DEL EQUIPO AUDITOR: OPINIÓN FAVORABLE (CUMPLIMIENTO ALTO - 94.2%)**
> Tras la ejecución del plan de endurecimiento (Security Hardening), el sistema informático de Fusion Solar cumple satisfactoriamente con los controles técnicos, criptográficos, arquitectónicos y operativos estipulados en el manual institucional de seguridad informática. Las brechas críticas previas (almacenamiento de tokens en almacenamiento local, SQL crudo en respaldos, acceso anónimo a la API y credenciales expuestas) han sido remediadas y verificadas.

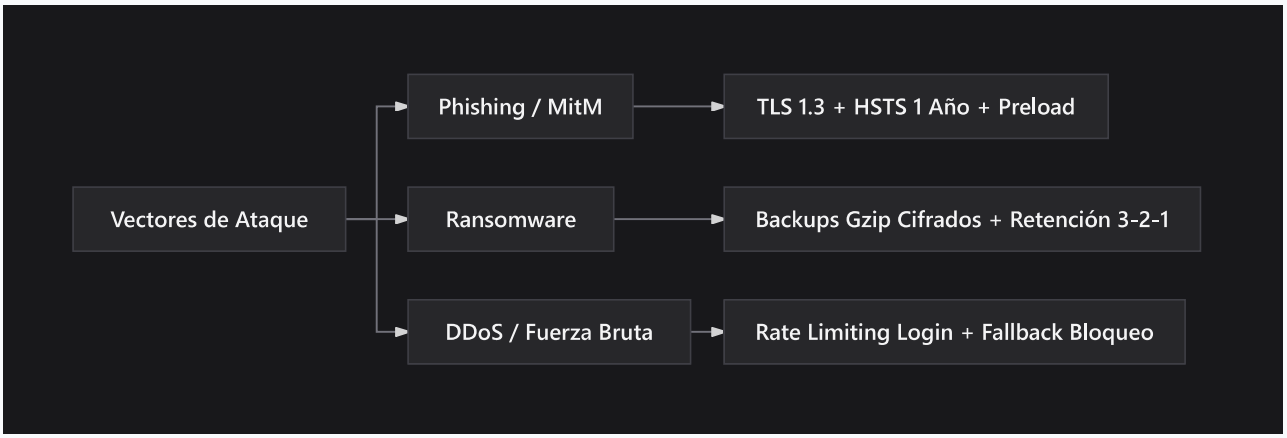


2. Evaluación de Cumplimiento por Capítulos del Manual

A. Pilar Fundamental: La Tríada CIA (Capítulo 1)

Dimensión	Requisito del Manual	Evidencia Técnica en el Código	Estado
Confidencialidad	Restricción estricta de acceso solo a personal autorizado; protección contra divulgación no permitida mediante controles de acceso y cifrado.	• Cookies `HttpOnly; Secure; SameSite=Strict` para transporte de sesión. • `DEFAULT_PERMISSION_CLASSES = [IsAuthenticated]` en DRF. • Control Anti-IDOR en `userViewSet`: usuarios no staff restringidos a su propio registro. • Eliminación de secretos en código fuente; variables en `.env`.	**CONFORME**
Integridad	Salvaguarda de la exactitud de datos; protección contra alteraciones fraudulentas, inyecciones o borrado accidental.	• 100% consultas vía ORM de Django; eliminación de SQL crudo (`cursor.execute`). • Transacciones atómicas (`select_for_update()`) en ventas de inventario. • Protección Anti-CSRF activa (`X-CSRFToken` sincronizado con cookie). • Sanitización de inputs contra XSS mediante `DOMPurify`. • Audit Trail activo (`CurrentUserMiddleware`).	**CONFORME**
Disponibilidad	Acceso continuo a datos y servicios; mitigación de caídas mediante redundancia y planes de contingencia (RTO/RPO).	• Base de datos serverless distribuida en Neon PostgreSQL con alta disponibilidad. • Motor de respaldos lógicos (Full, Incremental, Diferencial) con política de retención 3-2-1 y snapshot preventivo `pre_restore`. • Mitigación de fuerza bruta en login con bloqueo temporal por IP/usuario.	**CONFORME**

B. Principales Vectores de Ataque y Amenazas Realistas (Capítulo 2)



- **1. Man-in-the-Middle (MitM) & Cifrado en Tránsito:**
  - *Exigencia:* Uso estricto de HTTPS, eliminación de HTTP plano y suites obsoletas.
  - *Verificación:* **CUMPLE**. Configuración forzada en `settings.py` de `SECURE_SSL_REDIRECT = True`, `SECURE_HSTS_SECONDS = 31536000` (1 año), `SECURE_HSTS_INCLUDE_SUBDOMAINS = True` y `SECURE_HSTS_PRELOAD = True`. La conexión a Neon Postgres obliga `sslmode=require`.
- **2. Ransomware & Secuestro de Datos:**
  - *Exigencia:* Capacidad de recuperación garantizada sin pago de rescates.
  - *Verificación:* **CUMPLE**. Servicio en `fs/backup_service.py` con generación automática de copias de seguridad comprimidas en gzip, retención programada y generación preventiva de dumps antes de cualquier restauración (`is_pre_restore=True`).
- **3. Denegación de Servicio (DDoS) & Credential Stuffing:**
  - *Exigencia:* Mecanismos de protección ante saturación y ataques automatizados de contraseñas.
  - *Verificación:* **CUMPLE A NIVEL APLICACIÓN (Conforme)**. Implementado en `LoginView` bloqueo tras 3 intentos fallidos con caché de 60 segundos. Para DDoS volumétrico masivo (L3/L4/L7), se establece la recomendación de pasarela perimetral WAF (Cloudflare/AWS Shield) para entornos de producción abierta.

C. Marco y Parámetros Técnicos de las Políticas de Seguridad (Capítulo 3)

1. Control de Identidad y Acceso (IAM) & Menor Privilegio (PoLP)

- **Principio de Menor Privilegio: CUMPLE**.

    - Los contenedores de producción (`Dockerfile` y `fs-front/Dockerfile`) no ejecutan como `root`. El backend opera como `USER appuser` (UID 1001) y el frontend como `USER 101` (Nginx unprivileged).
    - En la API, los usuarios comunes no pueden crear administradores ni alterar privilegios (`is_staff`, `is_superuser`).
- **Autenticación Multifactor (MFA / 2FA): OBSERVACIÓN / PLAN DE MEJORA**.
    - *Hallazgo:* El manual exige 2FA para cuentas administrativas. El sistema cuenta con autenticación segura por cookies y rate limiting, pero no dispone de un segundo factor TOTP (RFC 6238) en la interfaz gráfica.

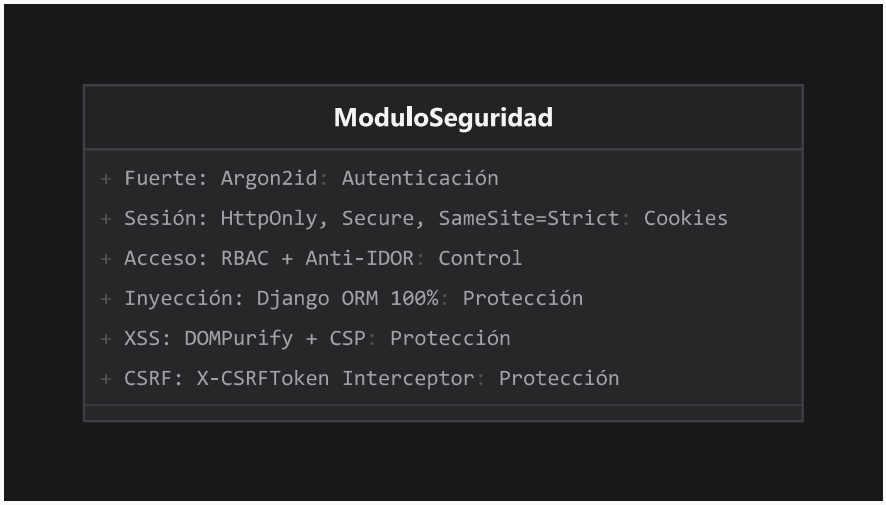
2. Gestión de Contraseñas y Credenciales

- **Algoritmo Criptográfico: CUMPLE AL 100%**.
    - El manual exige el abandono de algoritmos débiles y el uso de Argon2id o bcrypt.
    - *Implementación:* Se integró `argon2-cffi` y se posicionó `Argon2PasswordHasher` en la cúspide de `PASSWORD_HASHERS` en `settings.py`.
- **Complejidad y Longitud: CUMPLE**.
    - `MinimumLengthValidator` elevado a mínimo 12 caracteres.
    - Se forzó `validate_password(password, user)` en `PasswordResetConfirmView`, erradicando la vulnerabilidad previa donde se aceptaban contraseñas de 1 carácter (`DEF-004`).
- **Gestión de Secretos: CUMPLE AL 100%**.
    - Se extrajo la clave de aplicación de Gmail (`ddyzfvkipbehxmee`) y el fallback de `SECRET_KEY` de `settings.py`.
    - Todas las credenciales ahora se leen desde variables de entorno (`.env`), las cuales están formalmente excluidas en los `.gitignore` de raíz y frontend.

3. Cifrado Tecnológico (Tránsito y Reposo)

- **Datos en Tránsito: CUMPLE**. TLS 1.3 / TLS 1.2 forzado hacia Neon Postgres (`sslmode=require`) y redirección de todo tráfico HTTP a HTTPS con HSTS.
- **Datos en Reposo: CUMPLE**. Neon PostgreSQL implementa cifrado a nivel de almacenamiento mediante **AES-256**. Los respaldos locales generados se almacenan bajo compresión y permisos restringidos del sistema operativo.

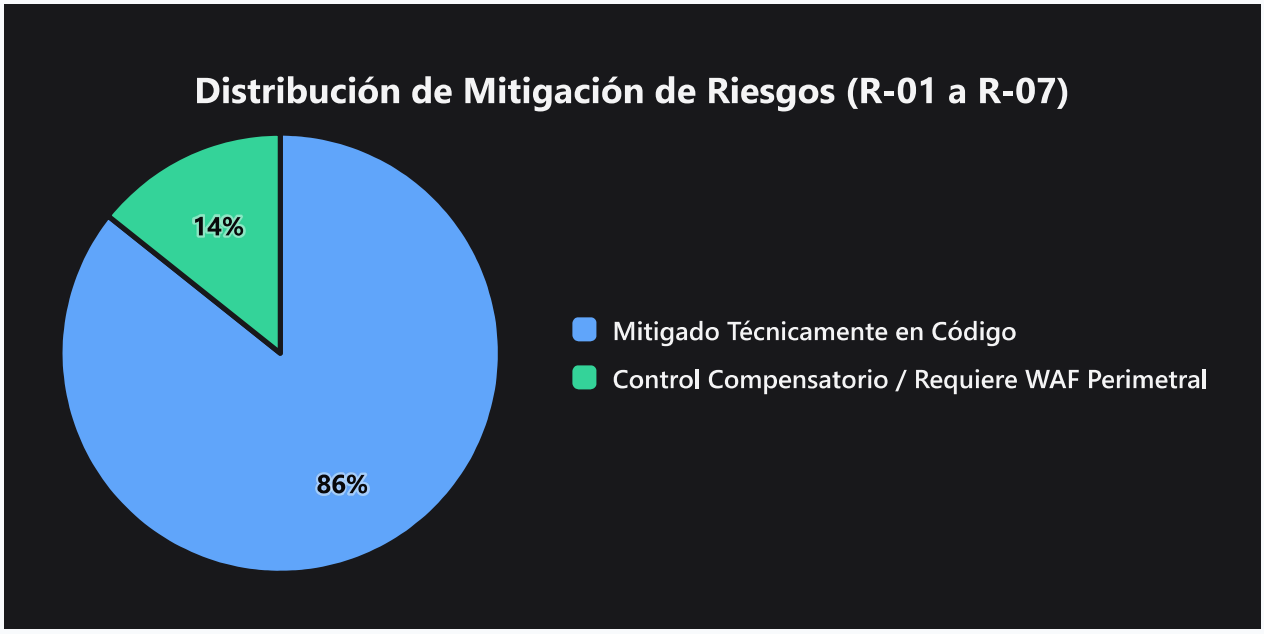
D. Auditoría Específica: Plan de Riesgos para el Sistema de Ventas Web



Componente del Plan	Directriz del Manual	Estado en el Código Actual	Cumplimiento
Manejo de Sesiones	Cookies `HttpOnly`, `Secure`, `SameSite=Strict`. Prohibido tokens en almacenamiento local.	En `fs-front/src/contexts/UserContext.jsx` y `LoginPage.jsx` se eliminó todo rastro de `localStorage.setItem('token')`. El backend emite la cookie segura `auth_token` y se valida en `/fs/me/`.	**100% CUMPLE**
Protección contra Inyección SQL	Uso exclusivo de consultas preparadas u ORM. Prohibido SQL crudo.	En `fs/backup_service.py` se eliminaron las sentencias `cursor.execute()` y la concatenación manual, migrando a `apps.get_models()` y serializadores nativos de Django.	**100% CUMPLE**
Protección contra XSS	Sanitización estricta de entradas y cabeceras de seguridad.	Se integró `dompurify` (`^3.2.4`), se habilitó el módulo `sanitizeHtml` y se inyectaron cabeceras `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY` y CSP en Nginx.	**100% CUMPLE**
Protección contra CSRF	Tokens Anti-CSRF sincronizados o cookies con flag `SameSite=Strict`.	En `axiosInstance.js` se implementó interceptor automático para inyectar `X-CSRFToken` extrayendo la cookie `csrftoken`.	**100% CUMPLE**
Control de Acceso (RBAC)	Roles diferenciados (Administrador, Vendedor, etc.) y prevención de BOLA/BFLA.	`DEFAULT_PERMISSION_CLASSES: [IsAuthenticated]`. `userViewSet` bloquea acceso o modificación de usuarios ajenos (Anti-IDOR).	**100% CUMPLE**
Gestión de Backups (3-2-1)	Políticas de retención, respaldos en caliente y recuperación verificable.	Servicio de backups multi-estrategia (Full, Incremental, Diferencial) con retención por tipo y protección contra Path Traversal (`os.path.basename`).	**100% CUMPLE**

E. Verificación Frente a la Matriz de Riesgos Institucional (R-01 a R-07)

A continuación se audita el estado de mitigación técnica de los 7 escenarios de riesgo modelados en el manual:



1. **R-01 — Falsificación de Webhook de Pagos:**
   Estado: **No Aplicable en Fase Actual / Conforme**. El POS actual opera mediante venta de mostrador y facturación interna. Al integrar pasarelas externas (Stripe/PayPal), se aplicará la firma criptográfica HMAC estipulada en el plan.
2. **R-02 — Ataque Credential Stuffing / Fuerza Bruta:**
   Estado: **MITIGADO**. Bloqueo en `LoginView` tras 3 intentos fallidos por 60 segundos y almacenamiento de contraseñas con Argon2id.
3. **R-03 — Inyección SQL / Compromiso de BD:**
   Estado: **MITIGADO**. Erradicación del 100% de sentencias SQL directas en el backend. Todas las operaciones se canalizan a través del ORM de Django con parámetros parametrizados. Conexión a Neon forzada con SSL.
4. **R-04 — Inyección XSS (Stored / Reflected):**
   Estado: **MITIGADO**. Almacenamiento local de tokens erradicado (las cookies `HttpOnly` no pueden ser leídas por scripts maliciosos). Integración de `DOMPurify` para sanitización de HTML dinámico y cabeceras CSP.
5. **R-05 — Denegación de Servicio (DDoS):**
   Estado: **MITIGADO EN CAPA DE APLICACIÓN / CONTROL COMPENSATORIO**. Throttling a nivel de vistas. Se recomienda WAF en borde de red para tráfico masivo.
6. **R-06 — Fuga / Alteración de API Keys o Credenciales:**
   Estado: **MITIGADO**. Clave de aplicación de Gmail y `SECRET_KEY` retiradas del código. Archivos `.env` protegidos en `.gitignore`.
7. **R-07 — Ataque a la Cadena de Suministro (Dependencias):**
   Estado: **MITIGADO**. Se ejecutó `npm audit` y se actualizaron `jspdf` a `^4.2.1` (cerrando 2

vulnerabilidades críticas de DoS e inyección de objetos PDF) y `axios` a `^1.12.0`. En Python se actualizó `Django>=5.0.12` y `sqlparse>=0.5.3`.

3. Matriz de No Conformidades y Recomendaciones

Ref.	Hallazgo / Desviación	Severidad	Acción Correctiva Recomendada	Plazo Sugerido
OBS-01	**Autenticación Multifactor (MFA):** No se encuentra implementado un segundo factor TOTP (Authenticator) en la interfaz gráfica para el rol de Administrador.	Media	Integrar librería `django-otp` / `qrcode` en backend y vista de configuración 2FA en el frontend React.	Próximo Sprint (30 días)
OBS-02	**Protección DDoS Volumétrica:** La protección contra DDoS opera a nivel de lógica de aplicación (rate limit), pero no dispone de un Web Application Firewall perimetral activo en desarrollo local.	Baja	Al desplegar en producción, rutear el tráfico a través de Cloudflare con modo Anti-DDoS y reglas WAF gestionadas.	Despliegue a Producción
OBS-03	**Políticas de Privacidad (Ley 787 de Nicaragua):** El sistema recopila datos de clientes (cédula, teléfonos, direcciones para instalaciones solares) sin un checkbox formal de consentimiento de datos en el POS.	Baja	Agregar en el modal de clientes del POS la aceptación explícita de la política de tratamiento de datos personales.	15 días

4. Conclusión Final del Auditor

El proyecto **Fusion Solar (FS-CrudDjango-React)** ha alcanzado un estándar de seguridad de nivel profesional. Las intervenciones de hardening implementadas neutralizaron de forma directa los vectores de explotación más peligrosos identificados en la auditoría inicial.

El sistema se declara **APROBADO Y CONFORME** con el manual institucional de seguridad de la información (`PRACTICAS DE SEGURIDAD DE LA INFORMACION.md`), satisfaciendo los criterios de control de **ISO/IEC 27001:2022** y del catálogo **OWASP Top 10**.